

# Supabase Database Audit Report

**Project:** Edeviser-Kiro (cdlgtbvxlxjpcddjazzx) **Region:** ap-northeast-1 **Postgres:** 17.6.1 **Audit Date:** April 1, 2026

## 1. Tables Overview (47 tables)

| #  | Table                | Purpose                                                                          | Rows | RLS |
|----|----------------------|----------------------------------------------------------------------------------|------|-----|
| 1  | institutions         | Multi-tenant root — each institution is a tenant                                 | 1    |     |
| 2  | profiles             | User accounts linked to auth.users<br>(admin/coordinator/teacher/student/parent) | 5    |     |
| 3  | programs             | Academic programs within an institution                                          | 0    |     |
| 4  | courses              | Courses within programs, assigned to teachers                                    | 0    |     |
| 5  | student_courses      | Enrollment junction (student ↔ course)                                           | 0    |     |
| 6  | learning_outcomes    | ILOs, PLOs, CLOs — the OBE outcome hierarchy                                     | 0    |     |
| 7  | outcome_mappings     | CLO→PLO→ILO weighted mappings                                                    | 0    |     |
| 8  | rubrics              | Grading rubrics linked to CLOs                                                   | 0    |     |
| 9  | rubric_criteria      | Individual criteria rows within a rubric                                         | 0    |     |
| 10 | assignments          | Assignments/quizzes/projects/exams per course                                    | 0    |     |
| 11 | submissions          | Student submissions for assignments                                              | 0    |     |
| 12 | grades               | Teacher grades for submissions (1:1 with submission)                             | 0    |     |
| 13 | evidence             | Immutable evidence records from grading → attainment rollup                      | 0    |     |
| 14 | outcome_attainment   | Aggregated attainment per outcome/student/course/scope                           | 0    |     |
| 15 | student_gamification | XP totals, level, streak, leaderboard opt-out per student                        | 0    |     |
| 16 | badges               | Earned badges per student (idempotent by student+badge_key)                      | 0    |     |
| 17 | xp_transactions      | Append-only XP ledger                                                            | 0    |     |
| 18 | journal_entries      | Student reflective journals per course/CLO                                       | 0    |     |
| 19 | audit_logs           | Append-only admin action audit trail                                             | 0    |     |
| 20 | notifications        | User notifications with read status                                              | 0    |     |
| 21 | habit_tracking       | Daily habit tracking (login/submit/journal/read)                                 | 0    |     |

|    |                          |                                                                |   |   |
|----|--------------------------|----------------------------------------------------------------|---|---|
| 22 | xp_events                | Admin-created bonus XP events with multipliers                 | 0 | ✓ |
| 23 | learning_path_nodes      | Prerequisite-gated assignment ordering per course              | 0 | ✓ |
| 24 | student_activity_log     | Append-only student activity events                            | 3 | ✓ |
| 25 | ai_feedback              | AI suggestion records with thumbs up/down feedback             | 0 | ✓ |
| 26 | semesters                | Academic semesters per institution                             | 0 | ✓ |
| 27 | departments              | Departments within an institution                              | 0 | ✓ |
| 28 | course_sections          | Sections within a course (teacher + capacity)                  | 0 | ✓ |
| 29 | surveys                  | Accreditation surveys (course exit, graduate exit, employer)   | 0 | ✓ |
| 30 | survey_questions         | Questions within surveys                                       | 0 | ✓ |
| 31 | survey_responses         | Individual survey responses                                    | 0 | ✓ |
| 32 | cqi_action_plans         | Continuous Quality Improvement action plans                    | 0 | ✓ |
| 33 | institution_settings     | Per-institution config (thresholds, grade scales, wellness XP) | 0 | ✓ |
| 34 | program_accreditations   | Accreditation status per program                               | 0 | ✓ |
| 35 | announcements            | Course announcements by teachers                               | 0 | ✓ |
| 36 | course_modules           | Content modules within courses                                 | 0 | ✓ |
| 37 | course_materials         | Files/links/videos within modules                              | 0 | ✓ |
| 38 | discussion_threads       | Discussion forum threads per course                            | 0 | ✓ |
| 39 | discussion_replies       | Replies within discussion threads                              | 0 | ✓ |
| 40 | class_sessions           | Individual class sessions for attendance                       | 0 | ✓ |
| 41 | attendance_records       | Per-student attendance per session                             | 0 | ✓ |
| 42 | quizzes                  | Quiz definitions with adaptive config                          | 0 | ✓ |
| 43 | quiz_questions           | Questions within quizzes                                       | 0 | ✓ |
| 44 | quiz_attempts            | Student quiz attempts with adaptive tracking                   | 0 | ✓ |
| 45 | grade_categories         | Weighted grade categories per course                           | 0 | ✓ |
| 46 | timetable_slots          | Weekly timetable slots per section                             | 0 | ✓ |
| 47 | academic_calendar_events | Institution calendar events                                    | 0 | ✓ |
| 48 | parent_student_links     | Parent ↔ student verified links                                | 0 | ✓ |
| 49 | fee_structures           | Fee definitions per program/semester                           | 0 | ✓ |

|    |                              |                                                                  |    |   |
|----|------------------------------|------------------------------------------------------------------|----|---|
| 50 | fee_payments                 | Student fee payment records                                      | 0  | ✓ |
| 51 | onboarding_questions         | Assessment questions for student onboarding                      | 55 | ✓ |
| 52 | onboarding_responses         | Student responses to onboarding assessments                      | 0  | ✓ |
| 53 | onboarding_progress          | Per-student onboarding wizard progress                           | 1  | ✓ |
| 54 | student_profiles             | Computed personality/learning style profiles                     | 0  | ✓ |
| 55 | baseline_attainment          | Pre-course CLO baseline scores                                   | 0  | ✓ |
| 56 | baseline_test_config         | Per-course baseline test configuration                           | 0  | ✓ |
| 57 | micro_assessment_schedule    | Scheduled micro-assessments for students                         | 0  | ✓ |
| 58 | starter_week_sessions        | AI-generated starter week study plan sessions                    | 0  | ✓ |
| 59 | goal_suggestions             | AI-generated SMART goal suggestions                              | 0  | ✓ |
| 60 | wellness_habit_logs          | Wellness habit tracking<br>(meditation/hydration/exercise/sleep) | 0  | ✓ |
| 61 | student_wellness_preferences | Per-student wellness settings and targets                        | 0  | ✓ |
| 62 | mastery_recovery_pathways    | CLO mastery recovery tracking for struggling students            | 0  | ✓ |
| 63 | question_bank                | AI-generated question bank with review workflow                  | 0  | ✓ |
| 64 | question_analytics           | Per-question performance analytics                               | 0  | ✓ |
| 65 | quiz_generation_logs         | AI quiz generation audit trail                                   | 0  | ✓ |
| 66 | verified_explanations        | Teacher-verified question explanations                           | 0  | ✓ |
| 67 | badge_spotlight_schedule     | Weekly badge spotlight rotation per institution                  | 0  | ✓ |

## 2. Installed Extensions

| Extension          | Schema     | Version | Purpose                           |
|--------------------|------------|---------|-----------------------------------|
| plpgsql            | pg_catalog | 1.0     | PL/pgSQL procedural language      |
| pg_stat_statements | extensions | 1.11    | Query performance tracking        |
| uuid-oss           | extensions | 1.1     | UUID generation                   |
| pgcrypto           | extensions | 1.3     | Cryptographic functions           |
| pg_net             | public     | 0.20.0  | Async HTTP calls from DB triggers |
| pg_cron            | pg_catalog | 1.6.4   | Scheduled job runner              |
| pg_graphql         | graphql    | 1.5.11  | GraphQL API support               |
| supabase_vault     | vault      | 0.3.1   | Secret management                 |

---

### 3. Functions & Triggers

#### Functions (7)

| Function                         | Args                     | Returns       | Purpose                                             |
|----------------------------------|--------------------------|---------------|-----------------------------------------------------|
| auth_user_role()                 | —                        | text          | Returns current user's role from profiles           |
| auth_institution_id()            | —                        | uuid          | Returns current user's institution_id from profiles |
| trigger_attainment_rollup()      | —                        | trigger       | Cascades evidence → attainment recalculation        |
| expire_stale_recovery_sessions() | —                        | integer       | Expires mastery recovery pathways past deadline     |
| get_wellness_aggregate_stats()   | p_institution_id<br>uuid | TABLE         | Aggregates wellness habit stats per institution     |
| health_check_ping()              | —                        | boolean       | Health check for monitoring                         |
| rls_auto_enable()                | —                        | event_trigger | Auto-enables RLS on new tables                      |

#### Triggers

No custom triggers found in public schema. The `trigger_attainment_rollup` function exists but no trigger binding was detected — this may be called from Edge Functions instead.

---

### 4. Views & Materialized Views

| View               | Type         | Purpose                                         |
|--------------------|--------------|-------------------------------------------------|
| leaderboard_weekly | Materialized | Pre-computed leaderboard with global rank by XP |

---

### 5. Storage Buckets

**No storage buckets found.** This is a gap — see recommendations below.

---

### 6. Edge Functions (1 deployed)

| Function | Status | Verify JWT |
|----------|--------|------------|
| health   | ACTIVE | No         |

Note: Your codebase has 20+ Edge Functions in `supabase/functions/` but only `health` is deployed. The rest are defined locally but not yet deployed to production.

---

## 7. RLS Policies Summary

All 67 tables have RLS enabled. Policies exist on most tables. Key patterns:

- Admin: full CRUD within institution ( `auth_user_role() = 'admin' AND institution_id = auth_institution_id()` )
- Teacher: CRUD on own courses ( `course_id IN (SELECT id FROM courses WHERE teacher_id = auth.uid())` )
- Student: read own data ( `student_id = auth.uid()` )
- Parent: read linked student data via `parent_student_links` with `verified = true`
- Coordinator: read/write within assigned programs

## 8. CRITICAL SECURITY ISSUES (from Supabase Advisor)

### ● Tables with RLS enabled but NO policies

| Table             | Risk                                    | Fix                                                       |
|-------------------|-----------------------------------------|-----------------------------------------------------------|
| evidence          | Data exposed to all authenticated users | Add institution-scoped read + append-only insert policies |
| learning_outcomes | All outcomes visible to everyone        | Add institution-scoped read + role-based write policies   |
| submissions       | All submissions visible to everyone     | Add student-own + teacher-course + admin read policies    |

### ● Functions with mutable search\_path

| Function                         | Risk                                |
|----------------------------------|-------------------------------------|
| auth_user_role()                 | Search path injection vulnerability |
| auth_institution_id()            | Search path injection vulnerability |
| get_wellness_aggregate_stats()   | Search path injection vulnerability |
| expire_stale_recovery_sessions() | Search path injection vulnerability |
| health_check_ping()              | Search path injection vulnerability |

Fix: Add `SET search_path = public` to each function definition.

### ● Extension in public schema

`pg_net` is installed in the `public` schema. Should be moved to `extensions` schema.

### ● Materialized view exposed to API

`leaderboard_weekly` is accessible to anon/authenticated roles without RLS. Should be wrapped with a function or have access restricted.

### ● Leaked password protection disabled

Supabase Auth's HavelBeenPwned check is disabled. Enable it in Dashboard → Auth → Settings.

## 9. MISSING ITEMS & RECOMMENDATIONS

### Missing Storage Buckets

Your codebase references file uploads (avatars, submissions, course materials) but no storage buckets exist:

| Bucket Needed         | Purpose                         | Public?           | Size Limit |
|-----------------------|---------------------------------|-------------------|------------|
| avatars               | User profile photos             | Yes (public read) | 2MB        |
| submissions           | Student assignment file uploads | No (private)      | 50MB       |
| course-materials      | Teacher-uploaded course content | No (private)      | 100MB      |
| accreditation-reports | Generated PDF reports           | No (private)      | 20MB       |

### Missing RLS Policies (3 tables)

**evidence** — needs:

```
-- Students read own evidence
CREATE POLICY "evidence_student_read" ON evidence FOR SELECT
  USING (student_id = auth.uid());
-- Staff read within institution
CREATE POLICY "evidence_staff_read" ON evidence FOR SELECT
  USING (auth_user_role() IN ('teacher','coordinator','admin'));
-- Append-only insert (from Edge Functions via service_role)
CREATE POLICY "evidence_service_insert" ON evidence FOR INSERT
  TO service_role WITH CHECK (true);
```

**learning\_outcomes** — needs:

```
-- Institution-scoped read
CREATE POLICY "outcomes_institution_read" ON learning_outcomes FOR SELECT
  USING (institution_id = auth_institution_id());
-- Admin/coordinator write
CREATE POLICY "outcomes_admin_write" ON learning_outcomes FOR ALL
  USING (auth_user_role() IN ('admin','coordinator') AND institution_id =
auth_institution_id());
-- Teacher write own course CLOs
CREATE POLICY "outcomes_teacher_write" ON learning_outcomes FOR ALL
  USING (auth_user_role() = 'teacher' AND course_id IN (SELECT id FROM courses WHERE
teacher_id = auth.uid()));
```

**submissions** — needs:

```
-- Student read/insert own
CREATE POLICY "submissions_student_own" ON submissions FOR ALL
  USING (student_id = auth.uid());
```

```
-- Teacher read for own courses
CREATE POLICY "submissions_teacher_read" ON submissions FOR SELECT
  USING (auth_user_role() = 'teacher' AND assignment_id IN (
    SELECT id FROM assignments WHERE course_id IN (
      SELECT id FROM courses WHERE teacher_id = auth.uid())));
```

### Missing student\_gamification Policies

The `student_gamification` table only has a parent read policy. Missing:

- Student read own: `student_id = auth.uid()`
- Admin/teacher read for institution
- Service role insert/update (for XP award Edge Functions)

### Missing audit\_logs Read Policy

Only has an admin INSERT policy. Needs admin SELECT policy for the audit log viewer page.

### Function search\_path Fixes

All 5 flagged functions need `SET search_path = public` added. This prevents search path injection attacks.

### Enable Leaked Password Protection

Go to Supabase Dashboard → Auth → Settings → Enable "Leaked password protection". This checks passwords against HaveIBeenPwned.

### Deploy Edge Functions

20+ Edge Functions exist in your codebase but only `health` is deployed. Deploy the critical ones:

- award-xp, process-streak, check-badges (gamification)
- calculate-attainment-rollup (OBE core)
- ai-at-risk-prediction, ai-feedback-draft, ai-module-suggestion (AI features)
- send-email-notification, weekly-summary-cron, streak-risk-cron (notifications)
- bulk-import-users, bulk-data-import (admin tools)

## 10. INDEX HEALTH

The database has 100+ indexes. Key observations:

- Full-text search indexes (GIN) on profiles, courses, assignments, announcements, course\_materials — good
- Leaderboard index on `student_gamification(xp_total DESC)` — good for ranking queries
- Composite unique indexes prevent duplicate enrollments, attendance, quiz attempts — good
- Missing: No index on `notifications(user_id, is_read)` — will be slow for unread notification counts at scale

### Recommended Additional Indexes

```
-- Fast unread notification count
CREATE INDEX idx_notifications_unread ON notifications(user_id, is_read) WHERE is_read =
false;
```

```
-- Fast journal lookup by student+course
CREATE INDEX idx_journal_student_course ON journal_entries(student_id, course_id, created_at
DESC);

-- Fast XP transaction sum per student
CREATE INDEX idx_xp_transactions_student_source ON xp_transactions(student_id, source);
```

## 11. BACKEND AUDIT

### Edge Functions (37 in codebase, 1 deployed)

| Function                      | Purpose                           | Deployed? |
|-------------------------------|-----------------------------------|-----------|
| health                        | Health check endpoint             | Yes       |
| award-xp                      | Award XP to students              | No        |
| process-streak                | Process daily login streaks       | No        |
| check-badges                  | Check and award badges            | No        |
| calculate-attainment-rollup   | Cascade evidence to attainment    | No        |
| ai-at-risk-prediction         | AI at-risk student prediction     | No        |
| ai-feedback-draft             | AI grading feedback drafts        | No        |
| ai-module-suggestion          | AI module recommendations         | No        |
| generate-quiz-questions       | AI quiz question generation       | No        |
| select-adaptive-question      | Adaptive quiz question selection  | No        |
| update-question-analytics     | Update question performance stats | No        |
| send-email-notification       | Transactional email via Resend    | No        |
| weekly-summary-cron           | Weekly email digest               | No        |
| streak-risk-cron              | Streak risk notifications         | No        |
| compute-at-risk-signals       | Compute at-risk student signals   | No        |
| compute-habit-correlations    | Habit-performance correlations    | No        |
| bulk-import-users             | CSV user import                   | No        |
| bulk-data-import              | CSV data import (courses, grades) | No        |
| export-student-data           | GDPR data export                  | No        |
| generate-accreditation-report | PDF accreditation report          | No        |
| generate-course-file          | Course file PDF generation        | No        |
| generate-fee-receipt          | Fee receipt PDF                   | No        |



|                           |                                 |    |
|---------------------------|---------------------------------|----|
| generate-transcript       | Student transcript PDF          | No |
| fee-overdue-check         | Fee overdue notifications       | No |
| exam-period-notify        | Exam period reminders           | No |
| process-onboarding        | Process onboarding responses    | No |
| suggest-goals             | AI goal suggestions             | No |
| generate-starter-week     | AI starter week plan            | No |
| check-login-rate          | Rate limit login attempts       | No |
| improvement-bonus-check   | Check improvement bonuses       | No |
| challenge-completion      | Challenge completion handler    | No |
| challenge-progress-update | Challenge progress tracker      | No |
| team-streak-risk-cron     | Team streak risk check          | No |
| import-competency-csv     | Competency framework CSV import | No |
| auto-grade-quiz           | Auto-grade quiz attempts        | No |
| notification-digest       | Notification digest sender      | No |
| perfect-day-prompt        | Perfect day nudge (6 PM)        | No |

## Auth & Access Control

- Auth provider: Supabase Auth (email/password)
- 5 roles: admin, coordinator, teacher, student, parent
- Role stored in `profiles.role` (user\_role enum)
- Helper functions: `auth_user_role()` , `auth_institution_id()`
- Multi-tenant: all data scoped by `institution_id`
- Parent access: verified via `parent_student_links.verified = true`
- Leaked password protection: DISABLED (needs manual enable)

## Error Handling & Logging

- Frontend: Sentry integration ( `@sentry/react` ) for error monitoring
- Backend: Edge Functions return structured JSON errors with status codes
- Audit trail: `audit_logs` table for admin actions (append-only)
- Activity tracking: `student_activity_log` for student events
- AI feedback: `ai_feedback` table with thumbs up/down tracking

---

## 12. FIXES APPLIED (April 1, 2026)

The following critical security issues were fixed via migration:

- Added RLS policies to `evidence` (student read, staff read, parent read)
- Added RLS policies to `learning_outcomes` (institution read, admin/coordinator/teacher write)
- Added RLS policies to `submissions` (student own, teacher read, admin read, parent read)

- Added RLS policies to `student_gamification` (student read, staff read)
  - Added RLS policy to `audit_logs` (admin read)
  - Fixed `search_path` on 5 functions (`auth_user_role`, `auth_institution_id`, `health_check_ping`, `expire_stale_recovery_sessions`, `get_wellness_aggregate_stats`)
  - Added 3 performance indexes (notifications unread, journal student+course, xp transactions student+source)
- 

## 13. REMAINING PERFORMANCE ISSUES

### Unindexed Foreign Keys (68 found)

The Supabase performance advisor flagged 68 foreign key columns without covering indexes. These will cause slow JOIN performance at scale. Key tables affected: `courses`, `learning_outcomes`, `evidence`, `assignments`, `submissions`, `discussion_replies`, `fee_payments`, `outcome_attainment`, `rubrics`, `quiz_questions`.

### RLS Policy Performance (60+ `auth_rls_initplan` warnings)

Many RLS policies use `auth.uid()` directly instead of `(select auth.uid())`. The subselect form is evaluated once per query instead of once per row. Affected tables include: `profiles`, `assignments`, `grades`, `submissions`, `badges`, `xp_transactions`, `journal_entries`, `notifications`, `quiz_attempts`, and many more.

Fix pattern: Replace `student_id = auth.uid()` with `student_id = (select auth.uid())` in all RLS policies.

### Multiple Permissive Policies (many tables)

Several tables have multiple permissive policies for the same role+action combination. Postgres evaluates ALL permissive policies with OR logic, which is slower than a single combined policy. Affected tables: `announcements`, `courses`, `assignments`, `grades`, `attendance_records`, `outcome_mappings`, and others.

### No Storage Buckets

No storage buckets configured. Needed for: `avatars`, `submissions`, `course-materials`, `accreditation-reports`.

---

## 14. PRIORITY ACTION ITEMS

1. Deploy critical Edge Functions (`award-xp`, `process-streak`, `check-badges`, `calculate-attainment-rollup`)
2. Create storage buckets (`avatars`, `submissions`, `course-materials`)
3. Enable leaked password protection in Auth settings
4. Add indexes to unindexed foreign keys (batch migration)
5. Optimize RLS policies with `(select auth.uid())` pattern
6. Sync migration locally: `npx supabase migration fetch --yes`